

OWASP

- 1) L'horodatage est essentiel pour les fonctionnalités de clocks, celles-ci sont implémentées via le serveur, le risque est donc accepté

Menace	Vulnérabilité	Cible												
↓	OuvrirVAS Divulgarion D'Informations Sur Les Horodatages TCP CVSS : 2.6 QdD : 80 %	Timemanager.freeboxos.fr												
Divulgarion D'Informations Sur Les Horodatages TCP <table><thead><tr><th>GRAVITÉ</th><th>STATUT</th><th>BALAYAGE</th><th>QUALITÉ DE DÉTECTION</th><th>CVSS</th><th>PORT</th></tr></thead><tbody><tr><td> Faible</td><td>☐ Ouvrir</td><td>OuvrirVAS</td><td>80% →</td><td>2.6 →</td><td>général/tcp</td></tr></tbody></table> Description L'hôte distant implémente les horodatages TCP et permet donc de calculer la disponibilité. L'hôte distant implémente les horodatages TCP, tels que définis par RFC1323/RFC7323. Un effet secondaire de cette fonctionnalité est que la disponibilité de l'hôte distant peut parfois être calculée. Solution Pour désactiver les horodatages TCP sous Linux, ajoutez la ligne 'net.ipv4.tcp_timestamps'. Références (4) https://datatracker.ietf.org/doc/html/rfc1323 https://datatracker.ietf.org/doc/html/rfc7323 https://web.archive.org/web/20151213072445/http://www.microsoft.com/en-us/download/details.aspx?id=9152 https://www.fortiguard.com/psirt/FG-IR-16-090			GRAVITÉ	STATUT	BALAYAGE	QUALITÉ DE DÉTECTION	CVSS	PORT	Faible	☐ Ouvrir	OuvrirVAS	80% →	2.6 →	général/tcp
GRAVITÉ	STATUT	BALAYAGE	QUALITÉ DE DÉTECTION	CVSS	PORT									
Faible	☐ Ouvrir	OuvrirVAS	80% →	2.6 →	général/tcp									

- 2) L'algorithme de chiffrement hmac-sha2-512 à été mis en place afin de palier le problème de MAC faible

Menace	Vulnérabilité	Cible												
↓	OuvrirVAS Algorithmes MAC Faibles Pris En Charge (SSH) CVSS : 2.6 QdD : 80 %	Timemanager.freeboxos.fr												
Algorithmes MAC Faibles Pris En Charge (SSH) <table><thead><tr><th>GRAVITÉ</th><th>STATUT</th><th>BALAYAGE</th><th>QUALITÉ DE DÉTECTION</th><th>CVSS</th><th>PORT</th></tr></thead><tbody><tr><td> Faible</td><td>☐ Ouvrir</td><td>OuvrirVAS</td><td>80% →</td><td>2.6 →</td><td>222/tc</td></tr></tbody></table> Description Le serveur SSH distant est configuré pour autoriser/prendre en charge des algorithmes MAC faibles. Solution Désactivez le ou les algorithmes MAC faibles signalés. Références (2) https://www.rfc-editor.org/rfc/rfc6668 https://www.rfc-editor.org/rfc/rfc4253#section-6.4			GRAVITÉ	STATUT	BALAYAGE	QUALITÉ DE DÉTECTION	CVSS	PORT	Faible	☐ Ouvrir	OuvrirVAS	80% →	2.6 →	222/tc
GRAVITÉ	STATUT	BALAYAGE	QUALITÉ DE DÉTECTION	CVSS	PORT									
Faible	☐ Ouvrir	OuvrirVAS	80% →	2.6 →	222/tc									

- 3) Le port 80 est obligatoirement ouvert car il redirige le trafic web vers l'application WEB, cependant le http est automatiquement redirigé vers le https

 Nmap
Port TCP Ouvert : 80

Port TCP Ouvert : 80

GRAVITÉ	STATUT	BALAYAGE	PORT
 Faible	☐ Ouvrir	Nmap	80

Description

Un port ouvert peut être une configuration attendue. Par exemple, les serveurs Web utilisent le port 80 pour desservir les sites Web sur http et le port 443 pour desservir les sites Web sur https. Pour une liste des ports couramment utilisés, consultez https://en.wikipedia.org/wiki/List_of_TCP_and_UDP_port_numbers. Un port ouvert inattendu pourrait donner un accès involontaire aux applications, aux données et aux réseaux privés. Les ports ouverts peuvent également être dangereux lorsque les services attendus sont obsolètes et exploités via des failles de sécurité.

- 4) Le port 443 dessert l'accès sécurisé à l'application web, le risque encouru est connu et accepté

 Nmap
Port TCP Ouvert : 443

Port TCP Ouvert : 443

GRAVITÉ	STATUT	BALAYAGE	PORT
 Faible	☐ Ouvrir	Nmap	443

Description

Un port ouvert peut être une configuration attendue. Par exemple, les serveurs Web utilisent le port 80 pour desservir les sites Web sur http et le port 443 pour desservir les sites Web sur https. Pour une liste des ports couramment utilisés, consultez https://en.wikipedia.org/wiki/List_of_TCP_and_UDP_port_numbers. Un port ouvert inattendu pourrait donner un accès involontaire aux applications, aux données et aux réseaux privés. Les ports ouverts peuvent également être dangereux lorsque les services attendus sont obsolètes et exploités via des failles de sécurité.

- 5) Le port 222 correspond au serveur ssh présent sur le serveur afin de faire le lien et pouvoir trigger les runners de github action, un fail to ban limite le nombre de requêtes autorisées à 5 par minute. Le contingent de limiter les adresses ip provenant de France est envisagé selon la récurrence constaté des bans.

 Nmap
Port TCP Ouvert : 222

Port TCP Ouvert : 222

GRAVITÉ	STATUT	BALAYAGE	PORT
 Moyen	☐ Ouvrir	Nmap	222

Description

Un port ouvert peut être une configuration attendue. Par exemple, les serveurs Web utilisent le port 80 pour desservir les sites Web sur http et le port 443 pour desservir les sites Web sur https. Pour une liste des ports couramment utilisés, consultez https://en.wikipedia.org/wiki/List_of_TCP_and_UDP_port_numbers. Un port ouvert inattendu pourrait donner un accès involontaire aux applications, aux données et aux réseaux privés. Les ports ouverts peuvent également être dangereux lorsque les services attendus sont obsolètes et exploités via des failles de sécurité.

- 6) Le module « Helmet » sera mis en place afin de mettre en place des en-têtes de sécurité par défaut dans le but de ne pas interpréter les ressources

 OWASPZAP
En-Tête X-Content-Type-Options Manquant
[Top 10 de l'OWASP](#)

Timemanager.freeboxos.fr

En-Tête X-Content-Type-Options Manquant

GRAVITÉ	STATUT	BALAYAGE	TOP 10 DE L'OWASP	IDENTIFIANT CWE
 Faible	☐ Ouvrir	OWASPZAP	Mauvaise configuration de la sécurité →	693 →

Description

L'en-tête Anti-MIME-Sniffing X-Content-Type-Options n'était pas défini sur « nosniff ». Cela permet aux anciennes versions d'Internet Explorer et de Chrome d'effectuer une détection MIME sur le corps de la réponse, ce qui peut potentiellement entraîner l'interprétation et l'affichage du corps de la réponse comme un type de contenu autre que le type de contenu déclaré. Les versions actuelles (début 2014) et anciennes de Firefox utiliseront le type de contenu déclaré (s'il est défini), plutôt que d'effectuer un reniflage MIME.

Solution

Assurez-vous que l'application/le serveur Web définit l'en-tête Content-Type de manière appropriée et qu'il définit l'en-tête X-Content-Type-Options sur « nosniff » pour toutes les pages Web. Si possible, assurez-vous que l'utilisateur final utilise un navigateur Web moderne et conforme aux normes qui n'effectue pas du tout de détection MIME, ou qui peut être invité par l'application Web/le serveur Web à ne pas effectuer de détection MIME.

Cas (9) **Références (2)**

TAPER
https://timemanager.freeboxos.fr/
https://timemanager.freeboxos.fr/assets/index-C56ahUu_.js
https://timemanager.freeboxos.fr/login
https://timemanager.freeboxos.fr/manifest.webmanifest
https://timemanager.freeboxos.fr/registerSW.js

- 7) « Helmet » permettra de mettre en place une politique CSP (Content-Security-Policy) pour définir quelles sources sont autorisées pour différents types de contenus

En-Tête De Politique De Sécurité Du Contenu (CSP) Non Défini

GRAVITÉ	STATUT	BALAYAGE	TOP 10 DE L'OWASP	IDENTIFIANT CWE
 Moyen	☐ Ouvrir	OWASPZAP	Mauvaise configuration de la sécurité →	693 →

Description

La politique de sécurité du contenu (CSP) est une couche de sécurité supplémentaire qui permet de détecter et d'atténuer certains types d'attaques, notamment les attaques de type Cross Site Scripting (XSS) et par injection de données. Ces attaques sont utilisées pour tout, du vol de données à la dégradation de sites ou à la distribution de logiciels malveillants. CSP fournit un ensemble d'en-têtes HTTP standard qui permettent aux propriétaires de sites Web de déclarer les sources de contenu approuvées que les navigateurs devraient être autorisés à charger sur cette page. Les types couverts sont JavaScript, CSS, les cadres HTML, les polices, les images et les objets intégrables tels que les applets Java, ActiveX, fichiers audio et vidéo.

Solution

Assurez-vous que votre serveur Web, serveur d'applications, équilibreur de charge, etc. est configuré pour définir l'en-tête Content-Security-Policy.

Cas (3) Références (7)

TAPER
https://timemanager.freeboxos.fr/
https://timemanager.freeboxos.fr/login
https://timemanager.freeboxos.fr/sitemap.xml

- 8) Les routes critiques vont être sécurisées, Access-Control-Allow-Origin sera restreint pour les routes nécessitant une authentification

Mauvaise Configuration Entre Domaines

GRAVITÉ	STATUT	BALAYAGE	TOP 10 DE L'OWASP	IDENTIFIANT CWE	IDENTIFIANT
 Moyen	☐ Ouvrir	OWASPZAP	Contrôle d'accès cassé →	264 →	14

Description

Le chargement des données du navigateur Web peut être possible en raison d'une mauvaise configuration du partage de ressources Cross Origin (CORS) sur le serveur Web.

Solution

Assurez-vous que les données sensibles ne sont pas disponibles de manière non authentifiée (en utilisant une liste blanche d'adresses IP, par exemple). Configurez l'en-tête HTTP « Access-Control-Allow-Origin » sur un ensemble de domaines plus restrictif, ou supprimez entièrement tous les en-têtes CORS, pour permettre au navigateur Web d'appliquer la politique de même origine (SOP) de manière plus restrictive.

Cas (9) Références (1)

TAPER
https://timemanager.freeboxos.fr/
https://timemanager.freeboxos.fr/assets/index-C56ahUu_.js
https://timemanager.freeboxos.fr/login
https://timemanager.freeboxos.fr/manifest.webmanifest
https://timemanager.freeboxos.fr/registerSW.js

- 9) Le container « Traefik » redirige déjà tout le trafic http vers du https

En-Tête Strict-Transport-Security Non Défini

GRAVITÉ	STATUT	BALAYAGE	TOP 10 DE L'OWASP	IDENTIFIANT CWE
 Faible	☐ Ouvrir	OWASPZAP	Mauvaise configuration de la sécurité →	319 →

Description

HTTP Strict Transport Security (HSTS) est un mécanisme de politique de sécurité Web par lequel un serveur Web déclare que les agents utilisateurs conformes (tels qu'un navigateur Web) doivent interagir avec lui en utilisant uniquement des connexions HTTPS sécurisées (c'est-à-dire HTTP en couches sur TLS/SSL). HSTS est un protocole de normalisation de l'IETF et est spécifié dans la RFC 6797.

Solution

Assurez-vous que votre serveur Web, serveur d'applications, équilibreur de charge, etc. est configuré pour appliquer Strict-Transport-Security.

Cas (9) Références (5)

TAPER
https://timemanager.freeboxos.fr/
https://timemanager.freeboxos.fr/assets/index-C56ahUu_.js
https://timemanager.freeboxos.fr/login
https://timemanager.freeboxos.fr/manifest.webmanifest
https://timemanager.freeboxos.fr/registerSW.js

10) Helmet frameguard préviendra la dissimulation de pages sur le site

En-Tête Anti-Piratage Manquant

GRAVITÉ	STATUT	BALAYAGE	TOP 10 DE L'OWASP	IDENTIFIANT CWE
 Moyen	☐ Ouvrir	OWASPZAP	Mauvaise configuration de la sécurité →	1021 →

Description

La réponse ne protège pas contre les attaques « ClickJacking ». Il doit inclure soit Content-Security-Policy avec la directive 'frame-ancestors', soit X-Frame-Options.

Solution

Les navigateurs Web modernes prennent en charge les en-têtes HTTP Content-Security-Policy et X-Frame-Options. Assurez-vous que l'un d'entre eux est défini sur toutes les pages Web renvoyées par votre site/application. Si vous vous attendez à ce que la page soit encadrée uniquement par des pages de votre serveur (par exemple, elle fait partie d'un FRAMESET), alors vous souhaitez utiliser SAMEORIGIN, sinon si vous ne vous attendez jamais à ce que la page soit encadrée, vous devez utiliser DENY. Vous pouvez également envisager de mettre en œuvre la directive « frame-ancestors » de la politique de sécurité du contenu.

Cas (3)

TAPER
https://timemanager.freeboxos.fr/
https://timemanager.freeboxos.fr/login
https://timemanager.freeboxos.fr/sitemap.xml

Références (1)

11) Il est actuellement possible d'ajouter un utilisateur selon son rôle avec une requête POST via Postman, les routes critiques vont être corrigées afin de ne pouvoir ajouter un administrateur que localement.

Conclusion : La mise en place du module « Helmet » permettra de sécuriser les en-têtes ce qui sécurisera une majeure partie des potentielles failles mentionnées, les routes critiques seront quant à elles sécurisées et limitées par rapport à leur usage.